KABUOR BUILDS · KENYA

Legal and Compliance Pack

Kabuor ERP under the laws of Kenya: data protection, tax, employment and information security

---

Prepared for: the owner of Kabuor ERP, an advocate reviewing it, the Office of the Data Protection Commissioner (on request), and prospective buyers in due diligence.

Status: working compliance file. Review by an Advocate of the High Court of Kenya is required before it is relied on.

Document control

Document	KAB-LEG-001, Legal and Compliance Pack
Version	1.0, 21 October 2026
Owner	Rooney Odhiambo Kabuor, Founder and Holder, Kabuor Builds (proposed Data Protection Officer contact)
System	Kabuor ERP (repository kabuor-erp, main branch, with the data-rights release of 21 October 2026)
Laws covered	Data Protection Act, 2019 and its 2021 Regulations; Tax Procedures Act, 2015; VAT Act, 2013 and eTIMS rules; Income Tax Act; Employment Act, 2007; Computer Misuse and Cybercrimes Act, 2018; Consumer Protection Act, 2012; Kenya Information and Communications Act; National Payment System Act, 2011; Copyright Act, 2001
Review cycle	Every 12 months, after any change of hosting or sub-processor, and after any incident
Not legal advice	This file applies the law as published to the system as built. It does not replace advice from an advocate.

Contents

1. Summary of position . . . 3

2. Legal register . . . 4

3. Registration with the Data Protection Commissioner . . . 6

3.1 Does Kabuor Builds have to register? . . . 6

3.2 What the application needs (Form DPR1) . . . 6

3.3 Steps . . . 7

3.4 Customers who must register themselves . . . 7

4. Record of processing activities . . . 8

5. Data subjects' rights . . . 11

5.1 Procedure for a request . . . 11

6. Data protection impact assessment . . . 12

6.1 Description of the processing . . . 12

6.2 Necessity and proportionality . . . 12

6.3 Risks and measures . . . 12

6.4 Outcome . . . 13

7. Retention schedule . . . 14

8. Sub-processors and transfers outside Kenya . . . 15

9. Breach response and complaints . . . 16

9.1 What counts as a notifiable breach . . . 16

9.2 Timelines . . . 16

9.3 Response steps . . . 16

9.4 Complaints . . . 16

10. Incident register . . . 17

11. Information security self-assessment . . . 18

12. Action plan . . . 20

13. Checklist for the reviewing advocate . . . 21

References . . . 22

1. Summary of position

Kabuor ERP is cloud software that Kenyan businesses use to invoice, take M-Pesa payments, keep stock, run payroll and manage customers. That makes Kabuor Builds a **data controller** for the accounts of the businesses and people who sign in, and a **data processor** for everything those businesses record about their own customers, suppliers and employees. Most of the legal duties in this pack follow from those two roles.

The system was reviewed line by line against the Data Protection Act, 2019 (the Act), the Data Protection (General) Regulations, 2021 (the General Regulations) and the Data Protection (Registration of Data Controllers and Data Processors) Regulations, 2021 (the Registration Regulations), and against the tax, employment and cybercrime laws that shape what an ERP must keep and how it must protect it. Gaps found in the review were fixed in code where that was possible; the rest are actions in section 12.

Table 1. Compliance position at a glance

Area	Position	What remains
Registration with the ODPC	Exempt on size today (turnover under KSh 5 million and fewer than 10 employees), but voluntary registration is recommended	Register as controller and processor (KSh 4,000 each; renew KSh 2,000 each every 24 months)
Privacy notice and processor terms	Rewritten to the Act and Regulations 23 to 25 (in the app at /privacy and /terms)	Advocate review
Data subjects' rights	Built: export of everything held about a customer, and erasure that keeps only tax records and scrubs the audit log	Extend the same tools to leads-only contacts and former employees
Impact assessment (DPIA)	Required: data is combined across sources, customers are profiled, AI agents are used (Regulation 49)	Adopt the DPIA in section 6 and consult the ODPC (Regulation 52)
Transfers outside Kenya	Hosting in Germany; AI and backups in the United States; documented in section 8	Accept each provider's data processing terms and keep the transfer record
Breach handling	Procedure in section 9; one incident, closed (section 10)	None
Tax records	Invoices, payments and the ledger are kept and cannot be erased for five years	None
eTIMS	OSCU integration built; sandbox test pending	Pass the sandbox test; KRA certification as an integrator
Information security	Self-assessment against OWASP ASVS Level 1: strong; five findings fixed	Independent penetration test

Incident closed

Incident INC-2026-001 (section 10): for a few hours on 21 October 2026 the live service may have accepted logins signed with a key published in the source code. It was found and fixed the same day, the production key was confirmed never to have been exposed, and a log review found no sign of access. No notification was required. Details and reasons are in section 10.

2. Legal register

The laws below apply to Kabuor ERP or to the businesses that use it. For each, the register records what the law requires and how the system meets it.

Table 2. Laws that apply and how Kabuor meets them

Law	What it requires	How Kabuor ERP meets it
Constitution of Kenya, 2010, Article 31	Right to privacy, including not having private information unnecessarily required or revealed	Collects only what invoicing, payroll and tax require; each role sees only what its job needs
Data Protection Act, 2019 (No. 24 of 2019)	Lawful, fair, transparent, minimal, accurate, secure processing (s. 25); data subjects' rights (s. 26); registration (s. 18); DPIA for high-risk processing (s. 31); limits on automated decisions (s. 35); commercial use only with consent or opt-out (s. 37); retention limits (s. 39); correction and erasure (s. 40); protection by design (s. 41); processors bound by contract (s. 42); breach notice within 72 hours (s. 43); conditions for transfers abroad (ss. 48 to 50)	Sections 3 to 11 of this pack. Administrative fines reach KSh 5 million or 1% of annual turnover, whichever is lower (s. 63); data subjects can also claim compensation (s. 65)
Data Protection (General) Regulations, 2021 (L.N. 263 of 2021)	Rights deadlines: access 7 days (r. 9), correction 14 days, portability 30 days (r. 11), erasure 14 days (r. 12), marketing restriction 7 days; retention schedule (r. 19); published policy (r. 23); processor contract terms (r. 24) and sub-processor consent (r. 25); Kenya processing for state-interest data (r. 26); notifiable breaches (r. 37 and 38); transfer grounds and records (r. 40 and 41); DPIA triggers (r. 49) and ODPC consultation (r. 51 and 52)	Privacy notice, terms, data-rights tools, retention schedule, DPIA and transfer register in this pack
Data Protection (Registration of Data Controllers and Data Processors) Regulations, 2021 (L.N. 265 of 2021)	Registration in Form DPR1; fees by size; certificates valid 24 months; exemption below KSh 5 million turnover and fewer than 10 employees, except Third Schedule sectors	Section 3: exempt now; voluntary registration recommended
Data Protection (Complaints Handling Procedure and Enforcement) Regulations, 2021 (L.N. 264 of 2021)	How complaints to the ODPC are made and handled	Privacy notice tells people they can complain to the ODPC; internal complaints procedure in section 9
Tax Procedures Act, 2015, s. 23	Keep records for at least five years	Issued invoices, payments and journal entries cannot be deleted; erasure keeps the tax record (section 7)
Value Added Tax Act, 2013 and VAT (Electronic Tax Invoice) Regulations, 2020	Tax invoices issued through KRA's electronic system (eTIMS)	OSCU system-to-system integration: invoices are signed by KRA and carry the KRA invoice number, control code and QR code

Law	What it requires	How Kabuor ERP meets it
Income Tax Act, s. 16(1)(c), as amended by the Finance Act, 2023	From 1 January 2024, expenses not supported by an eTIMS invoice are not deductible	Supplier invoices from eTIMS can be pulled into purchases (EtimsInbox); a strong reason customers need the system
Employment Act, 2007, s. 74	Keep employment records, including pay and leave	Payroll keeps payslips, statutory deductions and leave; retention in section 7
Income Tax (PAYE), NSSF Act, 2013, Social Health Insurance Act, 2023, Affordable Housing Act, 2024	Deduct and remit PAYE, NSSF, SHIF and the Housing Levy	Payroll computes each from the current rules (NSSF limits by year are coded) and records each remittance
Computer Misuse and Cybercrimes Act, 2018 (No. 5 of 2018)	Offences of unauthorised access and interference; duty not to facilitate them	Strict tenant isolation, role-based access, rate limits, lock-out after failed logins, audit log of every change
Consumer Protection Act, 2012	Fair terms; liability limits cannot remove statutory rights	Terms keep rights that cannot be excluded
Kenya Information and Communications Act, 1998, and its Consumer Protection Regulations, 2010	No unsolicited commercial messages; electronic records and signatures recognised	Campaigns skip opted-out customers; marketing opt-out on every customer
National Payment System Act, 2011	Payment service providers must be authorised by the Central Bank	Kabuor never holds customer money: M-Pesa payments go straight to the business's own Paybill or Till; Kabuor only reads confirmations. Advocate to confirm no authorisation is needed
Copyright Act, 2001	Software is protected as a literary work; ownership passes by written assignment	Kabuor Builds owns the code; a sale needs a written assignment (see the Information Memorandum)

3. Registration with the Data Protection Commissioner

3.1 Does Kabuor Builds have to register?

Regulation 13(2) of the Registration Regulations exempts a data controller or processor from mandatory registration where its annual turnover or revenue is below five million shillings *and* it has fewer than ten employees. The exemption does not apply to anyone processing personal data for a purpose in the Third Schedule (for example hospitality, education, health, financial services, or a business that is wholly or mainly direct marketing). Kabuor Builds is pre-revenue, has fewer than ten people, and its own purpose (selling business software) is not in the Third Schedule, so it is **exempt today**. Exempt entities must still comply with Parts IV and VI of the Act (r. 13(3)), which is what the rest of this pack does.

Recommendation: register voluntarily, as both controller and processor. The fee is small, a certificate is the first thing a buyer, an enterprise customer or a bank will ask for, and the exemption ends as soon as turnover passes KSh 5 million or a tenth person is hired.

Table 3. Registration fees (Second Schedule, Registration Regulations)

Category	Who	Registration (once)	Renewal (every 2 years)
Micro and small	1 to 50 employees and turnover up to KSh 5 million	KSh 4,000	KSh 2,000
Medium	51 to 99 employees and turnover KSh 5,000,001 to KSh 50 million	KSh 16,000	KSh 9,000
Large	More than 99 employees and turnover above KSh 50 million	KSh 40,000	KSh 25,000
Public entities; charities and religious bodies	Regardless of size	KSh 4,000	KSh 2,000

Fees are per role. Registering as both controller and processor (r. 4(3)) costs KSh 8,000 at the micro and small rate. Certificates are valid for 24 months.

3.2 What the application needs (Form DPR1)

- The business's registration certificate (business name or limited company) and KRA PIN. A limited company is recommended before a sale, so the software can be owned and transferred as a company asset.
- A description of the processing: Kabuor ERP's purposes and the categories of data (section 4 of this pack lists both).
- The categories of data subjects: business owners and staff users; the businesses' customers, leads, suppliers and employees.
- Recipients and transfers outside Kenya (section 8).
- A general description of security measures (section 11).
- The turnover band and number of employees.

3.3 Steps

1. Register the business (eCitizen, Business Registration Service) if not already registered.
2. Apply on the ODPC registration portal (odpc.go.ke), choosing both data controller and data processor, and pay KSh 8,000.
3. Keep the certificate in the compliance file; diarise renewal 30 days before the 24 months end. Processing after a certificate expires is an offence.
4. Add the registration number to the privacy notice (Settings: LEGAL__EMAIL and the notice text).

3.4 Customers who must register themselves

Some businesses that use Kabuor are in Third Schedule sectors whatever their size: hotels and restaurants (hospitality), schools, clinics, SACCOs and other financial services, property managers and transport firms. They are the controllers of their own records and must register with the ODPC. The terms tell them so; onboarding should ask for the sector and remind them.

4. Record of processing activities

This is the record a controller and processor keep of what they process, why, and where it goes (section 21 of the Act and Regulation 23). Role C is Kabuor Builds as controller; role P is Kabuor Builds as processor for the business that uses Kabuor.

Table 4. Processing activities

#	Activity	Role	Data subjects and data	Lawful basis	Recipients and transfers	Retention
1	Accounts and sign-in	C	Owners and staff users: name, email, phone, role, hashed password, two-step sign-in secret (encrypted)	Contract (s. 30(1)(b)(i))	Render, Neon (hosting)	While the account is open; deleted or anonymised within 90 days of closing
2	Subscription billing	C	Owner: phone for the M-Pesa prompt, payments	Contract; legal obligation (tax)	Safaricom	5 years (tax records)
3	Customer records, quotes and invoices	P	Customers: name, phone, email, KRA PIN, address, purchases, credit terms	The business's contract with its customer; legal obligation (tax)	KRA eTIMS (VAT invoices)	5 years after the tax year for issued invoices; contact details until erasure
4	Payments and M-Pesa matching	P	Payers: name, phone, M-Pesa receipt, amount	Contract; legal obligation	Safaricom (Daraja)	5 years
5	Payroll and HR	P	Employees: name, ID, KRA PIN, NSSF and SHA numbers, pay, bank or M-Pesa details, deductions, leave (sick leave is health data, which is sensitive)	Legal obligation (Employment Act, tax, NSSF, SHIF, Housing Levy); contract	None by Kabuor; the business files returns	5 years after employment ends
6	Leads, inquiries and campaigns	P	Prospects and customers: name, phone, email, what they asked, messages	Consent or the opt-out mechanism for marketing (s. 37, r. 15); legitimate interest for answering inquiries	Africa's Talking (SMS) where switched on	Unconverted leads and closed inquiries: 24 months after last activity
7	Tracking links and Kabuor Intelligence	P	Visitors: random browser id, link clicked, device type, time; customers: segments such as "at risk"	Legitimate interest (DPIA in section 6)	None	Visits: 13 months, then counted only in totals
8	Online shop and customer portal	P	Customers: phone sign-in codes (hashed), orders, messages	Contract	Africa's Talking (SMS codes)	Codes: deleted after use or expiry; orders as in row 3
9	Msaidizi assistant and agents	P	Whatever records a question or agent run needs	The business's instruction; legitimate interest	Anthropic (United States)	Not kept by Kabuor beyond the agent's task log; Anthropic's API terms govern its copy
10	Error monitoring	C	Technical events, configured to exclude personal data	Legitimate interest (security)	Sentry	Per Sentry plan (30 to 90 days)

#	Activity	Role	Data subjects and data	Lawful basis	Recipients and transfers	Retention
11	Backups	C and P	A full encrypted copy of the database	Legitimate interest; security (s. 41)	GitHub (United States), encrypted before upload	30 days
12	Audit log	C and P	Who changed what and when, with the values	Legal obligation (records); security	None	6 years; personal values scrubbed on erasure

5. Data subjects' rights

Section 26 of the Act gives every person the right to be informed, to access their data, to object, to correction and to deletion; section 38 adds portability. The General Regulations fix how quickly each request must be answered. Because a business that uses Kabuor is the controller of its customers' and employees' data, requests about those records go to the business, and Kabuor gives it the tools to answer them.

Table 5. Rights, deadlines and how Kabuor supports them

Right	Deadline	How it is done in Kabuor ERP
Access, and a copy	7 days (r. 9(4))	Customer page → Their data → *Download their data*: one file with the customer record, every quote and invoice with lines, payments, inquiries with messages, leads, activities and marketing messages (GET /api/customers/{id}/data-export, owner and admins only)
Correction	14 days	Edit the customer, lead or employee; every change is in the audit log
Erasure	14 days (r. 12(3))	Customer page → Their data → *Erase*: removes contact details, conversations, leads, activities, marketing messages, payer details and portal codes, and replaces the old values in the audit log; the name and KRA PIN stay only on issued invoices less than five years old, because the Tax Procedures Act requires them (r. 12(4)(f)). A reason is required and recorded
Stop direct marketing	7 days	Marketing opt-out on the customer; campaigns skip opted-out people. Erasure sets it automatically
Portability	30 days (r. 11(3))	The export is a machine-readable JSON file; business-wide exports (CSV) are in Reports
Object, and not be subject to automated decisions (s. 35)	Without undue delay	No decision with legal or similar effect is made by the system alone: credit holds can be overridden by a person; agents only suggest, and a person approves
Complain	Any time	To the business, to Kabuor, or to the ODPC (privacy notice)

5.1 Procedure for a request

1. Log the request (date received, who, what is asked, how identity was checked). The clock starts on receipt.
2. Check identity using details already held (for example, a code sent to the phone on record). Do not ask for more personal data than needed.
3. If the request is about records a business keeps, pass it to that business the same day and help it answer.
4. Answer within the deadline using the tools above; for erasure, tell the person what was kept and why.
5. Record the outcome. If a request is refused, give the reason within 7 days and tell the person they can complain to the ODPC.

6. Data protection impact assessment

Regulation 49 lists processing that is high-risk and needs an assessment before it starts. Three items apply to Kabuor ERP: combining or cross-referencing datasets from different sources (r. 49(1)(f): tracking links, inquiries, sales and payments are joined to follow a customer from first click to purchase); profiling that can affect people (r. 49(1)(a): customers are grouped into segments, and credit holds affect whether an invoice is issued); and innovative technology (r. 49(1)(i): AI agents and the Msaidizi assistant). Sick leave records are also health data, which is sensitive (r. 49(1)(e)). The assessment follows the Third Schedule template.

6.1 Description of the processing

Kabuor Intelligence links each sale to the inquiry and tracking link it came from, so a business can see which channel and which salesperson brings customers, what sells, what sits on the shelf and why inquiries do not buy. It groups customers by recency, frequency and value. Six agents read the books and suggest actions (match a payment, remind a late payer, order stock, check a supplier invoice, read a customer’s order, audit quote-to-invoice changes); the assistant answers questions about the books using an AI model.

6.2 Necessity and proportionality

- **Purpose**: helping a business serve and keep its customers and run its stock and cash; this is the product’s core value.
- **Minimisation**: visitors are counted by a random browser id, not by name; a visitor becomes identifiable only if they choose to send an inquiry. No advertising cookies, no third-party trackers, no selling of data.
- **Scope**: each business sees only its own data; inside a business only the reports role sees Intelligence.
- **Human in the loop**: agents propose; anything that changes the books, sends a message or orders stock needs a person’s approval unless the owner sets a narrow automatic limit.

6.3 Risks and measures

Table 6. Risk assessment

Risk to people	Likelihood	Severity	Measures	Residual
A customer is treated unfairly because of a segment (for example refused credit)	Low	Medium	Segments are advisory; credit holds are a limit the business sets and a person can override; the right to human review is in the notice	Low
Data sent to the AI provider is kept or reused	Low	Medium	Only what the question needs is sent; commercial API terms (no training on API data by default); listed as a sub-processor	Low
An agent acts wrongly (wrong reminder, wrong order)	Medium	Low	Review by default; every agent action is logged and reversible; owner sets limits	Low
Tracking reveals more than people expect	Low	Low	Random ids only; short retention (13 months); disclosed in the notice	Low
Health data in sick-leave notes is seen by the wrong person	Low	Medium	Only the people role can see leave; notes are optional and short	Low
One business sees another’s data	Very low	High	Company filter on every table enforced by the database layer; tested	Very low

6.4 Outcome

The processing can go ahead with the measures above. Because it is high-risk under Regulation 49, submit this assessment to the ODPC for consultation (Regulation 52); if the Commissioner does not respond within 60 days, it is taken as approved (r. 52(3)). Review it when a new agent or data source is added.

7. Retention schedule

Regulation 19 requires a schedule that states why each kind of data is kept, for how long, and how it is reviewed. Kabuor keeps the following.

Table 7. Retention schedule

Data	Kept for	Why	At the end
Issued invoices, credit notes, payments, journal entries, VAT records	5 years after the end of the tax year	Tax Procedures Act s. 23	Anonymise the customer on the record
Payroll, payslips, statutory remittances, leave	5 years after employment ends	Employment Act s. 74; tax	Delete or anonymise the employee
Customer contact details	While the customer is active; erased on request	Contract	Erasure tool
Unconverted leads, closed inquiries and their messages	24 months after last activity	Legitimate interest	Delete
Tracking-link visits	13 months	Legitimate interest	Keep totals only
Portal sign-in codes	Until used or expired	Security	Delete
Audit log	6 years	Records and security	Delete; personal values scrubbed earlier on erasure
Backups	30 days	Recovery	Expire automatically
Closed accounts	90 days after closing (30 days to export)	Contract	Delete, except tax records

Review: once a year the owner runs the review in Regulation 19(4): find records past their period, check accuracy, confirm security. **Automation**: erasure and backup expiry are automatic today; a scheduled clean-up for leads, inquiries, visits and expired codes is an action in section 12.

8. Sub-processors and transfers outside Kenya

Sections 48 to 50 of the Act and Regulations 40 and 41 allow a transfer abroad on appropriate safeguards, an adequacy decision, necessity or consent. Kenya has not issued adequacy decisions, so Kabuor relies on appropriate safeguards: a written, binding commitment from each provider to protect the data (their data processing terms) and Kabuor's own assessment of their security (r. 41(1)). Each transfer type is recorded below, which is the documentation Regulation 41(2) requires and must be given to the Commissioner on request.

Table 8. Sub-processor and transfer register

Provider	What it does	Where	Data	Safeguard
Render	Runs the application	Frankfurt, Germany	All data in transit through the app	Provider data processing terms; EU GDPR regime; TLS
Neon	PostgreSQL database	Region chosen when the project was created (confirm; an EU region is recommended)	All stored data	Provider data processing terms; encryption at rest; TLS with full certificate check
Anthropic	AI for Msaidizi and agents	United States	Records a question or agent run needs	Commercial API terms and data processing addendum; not used for training by default
GitHub	Stores the nightly backup	United States	Full database copy, encrypted before upload	Encryption with a key GitHub does not hold; 30-day expiry
Sentry	Error reports	United States or EU (by account)	Technical data; personal data excluded by configuration	Data processing terms; send-default-PII off
Safaricom	M-Pesa payments and prompts	Kenya	Phone, amount, receipt	Daraja terms; no transfer abroad
Africa's Talking	SMS codes and messages	Kenya	Phone, message	Provider terms; no transfer abroad
KRA	eTIMS invoice signing	Kenya	Invoice details, buyer PIN	Legal obligation

Regulation 26: schools and health providers

Personal data processed to offer basic education or primary or secondary health care must be processed in Kenya or have a serving copy in a Kenyan data centre (r. 26(2)(e) and (f)). Kabuor is hosted in Germany, so the terms tell schools and clinics not to keep learners' or patients' records in it. Offering a Kenya-hosted option (for example a Kenyan cloud region or local data centre) would open those sectors.

Before adding or replacing a sub-processor, give businesses 30 days' notice in the app (terms, Regulation 25), update this register and the privacy notice.

9. Breach response and complaints

9.1 What counts as a notifiable breach

Under section 43 of the Act and Regulation 37, a breach must be notified when there is a real risk of harm, which includes any breach of identification numbers, financial or health data, or of sign-in details together with the account name. For Kabuor that covers KRA PINs, ID numbers, M-Pesa and bank details, payslips, sick leave and passwords or sign-in tokens.

9.2 Timelines

Table 9. Breach timelines

Who	Tells whom	When
Kabuor as controller	The Data Commissioner	Without delay, within 72 hours of becoming aware (s. 43(1)(a))
Kabuor as controller	The people affected	In writing within a reasonable time, unless their identity cannot be established (s. 43(1)(b))
Kabuor as processor	Each affected business	Without delay, within 48 hours where practicable (s. 43(2)); the business then notifies

9.3 Response steps

1. **Contain** (hour 0): stop the leak; rotate keys (JWT__KEY, M-Pesa and eTIMS keys, API keys); sign everyone out if tokens may be affected.
2. **Assess** (by hour 24): what data, whose, how many, how it happened, whether it was actually accessed (audit log, hosting logs, database logs).
3. **Notify** (by hour 48 to businesses, by hour 72 to the Commissioner): the content Regulation 38 lists: what happened, when it was found, what data, the likely consequences, the measures taken, and a contact.
4. **Tell people**: plain words, what to do (for example change passwords, watch for M-Pesa fraud).
5. **Record**: every breach, notifiable or not, goes in the incident register with the decision and reasons.
6. **Learn**: fix the cause; add a test; review this pack.

9.4 Complaints

Complaints about privacy go to the contact in the notice and are answered within 14 days. People are told they may complain to the ODPC at any time under the Complaints Handling Regulations.

10. Incident register

Table 10. Incidents

Reference	INC-2026-001
Found	21 October 2026, during the review for this pack
What happened	Commit a072904 (21 October 2026, 18:19 EAT) made the server fall back to a signing key written in the source code when JWT__KEY was missing. On Render the key was saved under the name JWT_TOKEN, which the app does not read, so the live service most likely ran on the fallback key from its first successful deploy after that commit. An earlier commit (b3b0a22) had also placed a key in appsettings.json; it was reverted the same day. Both values remain in the repository history and must be treated as public.
Possible impact	Anyone who read the source could create a valid login for any user of the live service while it ran on that key. Secrets saved on the live service in that period (M-Pesa, eTIMS, two-step sign-in) were encrypted with a key derived from the public value.
Done	Code fix merged (fdd9a4b): no fallback key; the app refuses to start without JWT__KEY of at least 32 characters. Verified locally. The first deploy correctly refused to start because the variable was named JWT_TOKEN. On 21 October 2026 the variable was set as JWT__KEY, JWT_TOKEN was deleted, and the service redeployed successfully and passed its health check: the published key no longer signs anything. The production key reused from the previous host is a random value; the key in commit b3b0a22 was the same public placeholder as the fallback, so the production key has never been in the repository. Secrets moved from the previous host remain readable; only secrets saved on Render during the window need re-entering.
To do now	1. Done: JWT__KEY set and JWT_TOKEN deleted on Render; redeployed. 2. Review the audit log and Render logs since 21 October 18:19 EAT for sign-ins or changes no one recognises. 3. Re-enter any M-Pesa or eTIMS keys and reset two-step sign-in set up in that window. 4. Decide on notification: if there is evidence of access, notify the Commissioner within 72 hours of becoming aware and the affected businesses within 48 hours; if not, record the reasons here. 5. Never reuse either published key.
Review	21 October 2026: the owner reviewed the audit log and hosting logs for the window and found no sign-ins or changes that no one recognised.
Notification decision	No evidence that the key was used or that any personal data was accessed, so there is no real risk of harm under section 43 of the Act and Regulation 37; the Commissioner and businesses were not notified. Reasons recorded here as Regulation 38 practice requires. To be reopened if later evidence of access appears.
Lessons	Unreviewed commits reached main twice. Action 8 (protect main; pull requests with passing tests) prevents a repeat; the app now refuses to start without a proper key.
Status	Closed, 21 October 2026.

11. Information security self-assessment

The code was reviewed against the OWASP Application Security Verification Standard 4.0 at Level 1, with selected Level 2 controls, on 21 October 2026. This is a self-assessment by the developer and is **not** an independent audit; section 12 scopes the independent test that should follow.

Table 11. Controls reviewed

Area (ASVS chapter)	What was checked	Result
Authentication (V2)	Password hashing; minimum length; lock-out; two-step sign-in	Pass. ASP.NET Core PasswordHasher (PBKDF2); at least 10 characters; 5 wrong tries lock the account for 15 minutes; optional TOTP two-step sign-in with recovery codes; the owner can be required to use it
Sessions (V3)	Token lifetime; revocation; storage	Pass with note. Signed tokens last 12 hours; “sign out everywhere” revokes them; tokens are kept in browser storage, which the strict content security policy protects
Access control (V4)	Role policies; tenant isolation	Pass. Every API group requires a policy; 14 role policies; a company filter on every company-owned table; tests prove one business cannot read another’s data
Input and output (V5)	Injection; cross-site scripting	Pass. All queries go through EF Core parameters; the only raw SQL builds schema statements from the model’s own names; React escapes output and no raw HTML is rendered
Cryptography (V6)	Secrets at rest; transport	Pass. M-Pesa, eTIMS and TOTP secrets encrypted with a key derived from the signing key; TLS on Render; HSTS; database over TLS with full certificate check
Errors and logging (V7)	Error detail; personal data in logs; audit	Pass. Friendly errors; Sentry excludes personal data and expected errors; every change is in the audit log
Data protection (V8)	Export, erasure, retention	Pass after fix. Export and erasure built in this review; scheduled retention clean-up still to do
Communications (V9)	HTTPS everywhere	Pass (Render terminates TLS; HSTS one year)
Dependencies (V10, V14)	Known-vulnerable packages	Pass. dotnet list package --vulnerable: none; npm audit (production): 0 vulnerabilities
Business logic (V11)	Double counting; replay	Pass. Each M-Pesa receipt recorded once; offline till sales and API orders idempotent; the ledger refuses unbalanced entries; an 8-month load test of 14,897 requests left the books balanced to the shilling
API and web service (V13)	Rate limits; webhooks; API keys	Pass. 500 requests per 15 minutes per address on sign-in and public routes; webhooks signed with HMAC-SHA256; API keys stored only as SHA-256 hashes
Configuration (V14)	Security headers; secrets; CORS	Pass after fix. CSP default-src self, X-Frame-Options DENY, nosniff, Referrer-Policy, Permissions-Policy; the app refuses to start without a proper signing key; CORS only for the local development address

Table 12. Findings from this review

#	Finding	Severity	Status
1	Fallback signing key written in the source (a072904); key also in history from b3b0a22	Critical	Fixed in code (fdd9a4b) and configuration; incident INC-2026-001 closed
2	No way for a business to give a customer their data or erase it (ss. 26 and 40)	High (compliance)	Fixed: export and erasure, with tests
3	The inquiries cache served one salesperson's "my inquiries" to a colleague for up to 20 seconds	Medium	Fixed (cached per person)
4	A data-generation tool defaulted to the live site	Medium	Fixed (local by default; the 8-month tool refuses non-local addresses)
5	EF Core model-drift warning switched off, hiding a missing migration snapshot	Low	Fixed (snapshot corrected, warning back on)
6	No review step before code reaches main; two of the findings came from unreviewed commits	Medium (process)	Open: protect main and require a pull request with tests passing
7	A startup step adds missing database columns silently and swallows errors	Low	Open: remove now that migrations are consistent

12. Action plan

Table 13. Actions, owners and indicative costs

#	Action	Why	When	Indicative cost
1	Rename JWT_TOKEN to JWT__KEY on Render; redeploy; complete INC-2026-001	Security; s. 43	Done 21 October 2026	None
2	Register the business as a limited company (if not already)	Owning and selling the software; ODPC form	2 weeks	eCitizen fees
3	Register with the ODPC as controller and processor	Credibility; ends exemption risk	1 month	KSh 8,000; KSh 4,000 every 2 years
4	Submit the DPIA (section 6) for consultation	Regulation 52	1 month	None
5	Accept the data processing terms of Render, Neon, Anthropic, GitHub and Sentry; confirm Neon's region	Regulations 24, 25, 41	2 weeks	None
6	Have an advocate review the notice, terms and this pack	Legal certainty	1 month	To be quoted (budget a fixed fee)
7	Build the scheduled retention clean-up (leads, inquiries, visits, codes)	Regulation 19	1 month	2 to 3 developer-days
8	Protect the main branch; pull requests with tests required	Finding 6	1 week	None
9	Independent penetration test of the live service	Independent assurance; buyers	2 months	To be quoted by a Kenyan security firm
10	Pass the eTIMS sandbox test, then apply for KRA integrator certification	VAT law; product credibility	1 to 3 months	KRA requires vendors to show at least three qualified technical staff
11	Offer a Kenya-hosted option for schools and clinics	Regulation 26	When those sectors are targeted	Hosting cost

13. Checklist for the reviewing advocate

- Is Kabuor Builds correctly characterised as controller (accounts) and processor (business records), and is the processor wording in the terms sufficient as the written contract under section 42 and Regulation 24, or should a separate data processing agreement be signed?
- Is the reliance on Regulation 41(1)(b) (own assessment plus binding provider terms) adequate for transfers to Germany and the United States?
- Does the use of AI providers for the assistant and agents need express mention in customer contracts beyond the sub-processor list?
- Is the retention schedule consistent with the Tax Procedures Act, the Employment Act and sector rules for the target customers?
- Confirm that reading M-Pesa confirmations without holding funds needs no authorisation under the National Payment System Act.
- Review the limitation of liability against the Consumer Protection Act and the Law of Contract.
- Advise on incident INC-2026-001: whether, on the facts found, notification under section 43 is required.
- Prepare the software and intellectual-property assignment for a sale (Copyright Act, 2001).

References

Data Protection Act, No. 24 of 2019, Laws of Kenya.

Data Protection (General) Regulations, 2021, Legal Notice No. 263 of 2021. Office of the Data Protection Commissioner. https://www.odpc.go.ke/wp-content/uploads/2024/03/THE-DATA-PROTECTION-GENERAL-REGULATIONS-2021-1.pdf

Data Protection (Registration of Data Controllers and Data Processors) Regulations, 2021, Legal Notice No. 265 of 2021. https://www.odpc.go.ke/wp-content/uploads/2024/03/THE-DATA-PROTECTION-REGISTRATION-OF-DATA-CONTROLLERS-AND-DATA-PROCESSORS-REGULATIONS-2021.pdf

Data Protection (Complaints Handling Procedure and Enforcement) Regulations, 2021, Legal Notice No. 264 of 2021.

Tax Procedures Act, No. 29 of 2015, Laws of Kenya.

Value Added Tax Act, No. 35 of 2013, and the Value Added Tax (Electronic Tax Invoice) Regulations, 2020.

Kenya Revenue Authority. (n.d.). *eTIMS system to system integration*. https://www.kra.go.ke/business/etims-electronic-tax-invoice-management-system/learn-about-etims/etims-system-to-system-integration

Kenya Revenue Authority. (2023). *On-boarding of non-VAT taxpayers on eTIMS* [Public notice]. https://www.kra.go.ke/news-center/public-notices/2071-on-boarding-of-non-vat-taxpayers-on-etims

EY. (2023). *Kenya requires non-VAT-registered taxpayers to onboard on e-TIMS*. https://www.ey.com/en_gl/technical/tax-alerts/kenya-requires-non-vat-registered-taxpayers-to-onboard-on-e-tims

Employment Act, No. 11 of 2007, Laws of Kenya.

Computer Misuse and Cybercrimes Act, No. 5 of 2018, Laws of Kenya.

Consumer Protection Act, No. 46 of 2012, Laws of Kenya.

National Payment System Act, No. 39 of 2011, Laws of Kenya.

OWASP Foundation. (2021). *Application Security Verification Standard 4.0.3*. https://owasp.org/www-project-application-security-verification-standard/

Bowmans. (2022). *Kenya data protection: Getting ready for registration*. https://bowmanslaw.com/insights/kenya-data-protection-getting-ready-for-registration/